

AIRBUS

Direction des Systèmes d'Information, Infrastructure et Sécurité Réseau

Sécurité du laboratoire virtualisé

Origine des logiciels, sécurité du code et exposition du poste

|              |                                              |          |                |
|--------------|----------------------------------------------|----------|----------------|
| Demandeur    | Stagiaire, Infrastructure et Sécurité Réseau | Date     | 18 août 2026   |
| Destinataire | Responsable de la sécurité des SI            | Validité | Durée du stage |

Périmètre, en trois phrases

Le laboratoire tient sur un poste unique, raccordé au port réseau dédié fourni par le service, et n’est utilisé que **depuis les locaux d’Airbus**. Aucun accès distant n’est demandé, aucune exposition sur Internet, aucun tunnel, aucune dérogation. Ce document traite les trois points soulevés : l’origine vérifiée des systèmes et des paquets, la sécurité du code produit, et la démonstration que le laboratoire ne crée pas de risque pour le réseau de l’entreprise.

1. Le poste et son raccordement

Le poste exécute deux systèmes en double amorçage : le Windows d’entreprise, inchangé, et un Ubuntu Server 24.04 LTS sur une partition dédiée. Seul ce dernier porte le laboratoire. Il n’a pas d’interface graphique, ce qui réduit d’autant la surface exposée, et héberge un hyperviseur KVM sur lequel tournent six machines virtuelles reliées par sept réseaux virtuels internes en 10.10.0.0/16.

Le service a fourni un **port réseau dédié** et un accès Internet pour ce projet. Cette séparation est en soi une mesure de sécurité : le laboratoire ne partage pas le segment des postes de travail.

L’accès au système se fait par SSH depuis un poste voisin, à l’intérieur des locaux. Ce choix n’ouvre aucun flux nouveau vers l’extérieur : il évite seulement de travailler sur une console physique, ce qui serait improductif et conduirait à laisser une session ouverte devant l’écran.

TABLEAU 1. Versions retenues, vérifiables à tout moment

| Composant    | Version                  | Contrôle       |
|--------------|--------------------------|----------------|
| Système hôte | Ubuntu Server 24.04 LTS  | lsb_release -a |
| Service SSH  | OpenSSH 9.6p1            | ssh -V         |
| Hyperviseur  | libvirt 10.0.0, QEMU/KVM | virsh version  |

## 2. Origine et intégrité des systèmes et des paquets

C'est le premier point soulevé. La règle applicable est **R59** du guide ANSSI-BP-028 v2.0, de niveau minimal : seuls les dépôts officiels de la distribution ou d'un éditeur doivent être utilisés.

**Aucun composant du projet ne provient d'une source tierce**, d'un agrégateur de téléchargement, d'un partage pair à pair ou d'une version modifiée. Aucune licence n'est contournée : les logiciels sont soit libres, soit utilisés dans le cadre d'une évaluation officielle de l'éditeur, soit acquis par l'entreprise.

**TABLEAU 2.** Origine et vérification de chaque composant

| Composant                 | Source officielle                              | Vérification appliquée                                                                                               |
|---------------------------|------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|
| ISO Ubuntu 24.04          | releases.ubuntu.com                            | Signature GPG du fichier de sommes, clé 843938DF...EFE21092, puis SHA-256                                            |
| Image cloud Ubuntu 22.04  | cloud-images.ubuntu.com                        | Idem, avec une <b>clé distincte</b> D2EB4462...7DB87C81                                                              |
| Paquets système Terraform | Dépôts Ubuntu officiels<br>Dépôt APT HashiCorp | Signature APT de l'archive, clé F6ECB376...991BC93C<br>Dépôt signé, clé 798AEC65...A621E701 référencée par signed-by |
| Collections Ansible       | Ansible Galaxy                                 | ansible-galaxy collection verify, versions épinglées et archivées dans le dépôt                                      |
| ISO Windows Server 2022   | Microsoft Evaluation Center                    | Évaluation officielle de 180 jours, empreinte locale consignée                                                       |
| Images constructeur       | Portails éditeur authentifiés                  | Sommes publiées par l'éditeur                                                                                        |

Vérifier la somme seule ne prouverait rien si le fichier de sommes venait de la même source que l'image. C'est la signature GPG de ce fichier, contrôlée contre une empreinte connue par ailleurs, qui fonde la confiance.

```
gpg --keyid-format long --verify SHA256SUMS.gpg SHA256SUMS
sha256sum -c --ignore-missing SHA256SUMS
```

### Quatre maillons faibles, déclarés plutôt que masqués

**Microsoft ne publie aucune somme de contrôle** pour les ISO de son centre d'évaluation. **Ansible Galaxy ne fournit aucune signature GPG**, seulement une chaîne d'empreintes interne à l'archive. **Fortinet publie une empreinte MD5**, qui ne satisfait pas le référentiel ANSSI exigeant au minimum 256 bits. Enfin, les paquets Ansible d'Ubuntu 24.04 relèvent du composant *universe* et ne bénéficient donc pas de la maintenance de sécurité de Canonical.

Dans les quatre cas, la mesure compensatoire est identique : téléchargement en HTTPS depuis le domaine de l'éditeur, calcul d'une empreinte SHA-256 de référence consignée au dossier de recette, et versions épinglées dans le dépôt, ce qui permet de détecter toute substitution ultérieure.

L'accès Internet fourni sert à ces téléchargements et aux correctifs de sécurité. Les machines virtuelles, elles, ne sortent que **pendant l'installation de leurs paquets**. Le paramètre correspondant est prévu pour être refermé ensuite, et deux VLAN sur sept seulement disposaient de cette sortie temporaire.

```
# infrastructure/terraform.tfvars
acces_internet_construction = false # repasse a false une fois les paquets installes
```

## 3. Sécurité du code produit

L'infrastructure entière est décrite en code, avec Terraform pour les machines et Ansible pour leur configuration. Cela présente un avantage de sécurité direct : tout est relisible, versionné, et reproductible à l'identique. Cela crée aussi un risque propre, celui de laisser fuiter un secret dans un dépôt.

### Aucun secret en clair

Les mots de passe et clés d'API ne figurent jamais dans le code. Ils sont remplacés par des renvois vers un coffre chiffré par `ansible-vault`. Le contrôle est reproductible : la recherche de motifs de secrets sur l'ensemble des fichiers versionnés ne remonte que des renvois de ce type.

```
# ansible/inventaire/group_vars/all.yml : aucune valeur, uniquement des renvois
password: "{{ coffre_paloalto_mot_de_passe }}"
ansible_fortios_api_key: "{{ coffre_fortinet_cle_api | default('') }}"
```

## Les fichiers sensibles ne peuvent pas être versionnés

L'état Terraform contient des informations sensibles, et les fichiers de paramètres contiennent des chemins et des clés propres à la machine. Tous sont exclus du versionnement, ce qui se vérifie fichier par fichier.

```
git check-ignore -v infrastructure/terraform.tfstate # état Terraform
git check-ignore -v infrastructure/terraform.tfvars # paramètres locaux
git check-ignore -v ansible/inventaire/hosts.yml # inventaire genere
git check-ignore -v vault-pass.txt # mot de passe du coffre
```

Un contrôle automatique complète cette exclusion. Un *crochet* de pré-commit refuse tout envoi contenant un coffre non chiffré ou une clé privée, de sorte qu'une inattention ne puisse pas se transformer en fuite.

```
git config core.hooksPath .githooks # activation, une fois par poste
# Essai : commit d'un coffre en clair
REFUS : ansible/inventaire/group_vars/coffre.yml n'est pas chiffré.
Lancer : ansible-vault encrypt ansible/inventaire/group_vars/coffre.yml
```

## Les machines sont fermées dès leur premier démarrage

Le durcissement n'attend pas une intervention manuelle. Il est posé par le gabarit d'amorçage, avant même que la machine ne soit joignable : compte sans mot de passe utilisable, compte root désactivé, authentification par mot de passe refusée, pare-feu local en refus entrant n'ouvrant que le port SSH.

```
lock_passwd: true # aucun mot de passe utilisable sur le compte
disable_root: true # compte root desactive
ssh_pwauth: false # authentification par mot de passe refusee
```

## Les versions sont figées

Une dépendance qui change seule est une porte d'entrée. Le fournisseur Terraform est épinglé, les collections Ansible le sont également et sont archivées dans le dépôt, ce qui rend le déploiement reproductible et insensible à une modification amont.

## Le code est contrôlé avant toute exécution

Trois outils sont passés systématiquement, et leur résultat est reproductible par un tiers.

**TABLEAU 3.** Contrôles appliqués au code du projet

| Contrôle             | Commande           | Résultat                   |
|----------------------|--------------------|----------------------------|
| Cohérence Terraform  | terraform validate | Succès                     |
| Syntaxe des fichiers | yamllint .         | Aucune remarque            |
| Qualité Ansible      | ansible-lint       | 0 échec, profil production |

Ces contrôles ne sont pas cosmétiques. Le profil *production* d'ansible-lint a par exemple intercepté deux appels de modules inexistantes, qui auraient échoué en cours de déploiement sur les pare-feux.

## 4. Exposition : ce que le laboratoire ne peut pas atteindre

C'est le point qui limite le plus la portée d'un incident, et il se démontre.

Les sept réseaux virtuels sont créés par libvirt en mode nat. Dans ce mode, la seule règle entrante posée est une acceptation **conditionnée à l'état de la connexion**, immédiatement suivie d'un rejet attrape-tout. Autrement dit, seules les réponses à des connexions initiées depuis une machine virtuelle traversent : **aucune connexion ne peut être initiée depuis le réseau d'Airbus vers le laboratoire**. En sortie, seuls les paquets dont l'adresse source appartient au sous-réseau déclaré sont acceptés, ce qui interdit toute usurpation d'adresse.

S'ajoute une seconde barrière, indépendante du filtrage : aucun équipement du réseau d'entreprise ne dispose d'itinéraire vers ces préfixes.

```
sudo iptables -L LIBVIRT_FWI -n -v # regles entrantes posees par libvirt
sudo ufw status numbered          # port 22 restreint au segment du laboratoire
```

Par honnêteté méthodologique : ce n'est pas la traduction d'adresse qui protège, contrairement à ce que l'on lit souvent, c'est le filtrage à état. Le mode open de libvirt, qui n'installe aucune règle, est proscrit dans ce projet, de même que sa fonction de redirection de port.

Le service SSH n'est joignable que depuis le segment du laboratoire, en authentification par clé exclusivement, et en droits positifs conformément à **R22** de la note ANSSI DAT-NT-007.

```
PermitRootLogin no
PasswordAuthentication no
AuthenticationMethods publickey
AllowGroups labo-admins
MaxAuthTries 3
LogLevel VERBOSE
```

Le niveau VERBOSE n'est pas un excès de zèle : au niveau par défaut, les échecs d'authentification par clé ne sont pas journalisés. Il apporte en outre l'empreinte de la clé employée à chaque connexion acceptée, ce qui fonde l'imputabilité exigée par **R33** du guide ANSSI-BP-028.

## 5. Risques, et ce que le dispositif ne couvre pas

TABLEAU 4. Événements redoutés et risque résiduel

| Événement redouté                                   | G  | V  | Mesures                                                                                                   | Résiduel                    |
|-----------------------------------------------------|----|----|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Composant altéré introduit par la chaîne logicielle | G4 | V2 | Sources officielles, signatures vérifiées, empreintes consignées, versions épinglées                      | Moyen                       |
| Fuite d'un secret par le dépôt de code              | G3 | V2 | Secrets en coffre chiffré, fichiers sensibles exclus, refus automatique au commit                         | Faible                      |
| Rebond du laboratoire vers le réseau d'entreprise   | G4 | V1 | Filtrage à état sans connexion entrante possible, absence de route, contrôle d'adresse source, port dédié | Faible                      |
| Accès non autorisé au service SSH                   | G2 | V1 | Accès local uniquement, clé exclusivement, droits positifs, journalisation détaillée                      | Faible                      |
| Atteinte au Windows d'entreprise depuis Ubuntu      | G4 | V2 | Dépend d'une décision qui ne m'appartient pas, voir ci-dessous                                            | <b>Élevé sans BitLocker</b> |

Le seul événement réellement grave n'est pas la perte du laboratoire, qui se reconstruit par une commande puisque toute son infrastructure est décrite en code. C'est l'atteinte au système d'information de l'entreprise, et l'ensemble du dispositif est conçu autour de cette hiérarchie.

### Trois limites que j'assume

**Le double amorçage est le point faible.** Aucun référentiel de l'ANSSI ne le valide comme mécanisme de cloisonnement, le modèle de référence étant un socle hyperviseur avec une machine virtuelle par environnement. La partition système EFI est partagée et non chiffrée, et surtout, **sans BitLocker actif, un administrateur d'Ubuntu lit et modifie l'intégralité de la partition Windows**. C'est le point le plus important de ce dossier, et

sa maîtrise ne m'appartient pas : je demande que l'état de BitLocker soit vérifié avant la mise en service. Secure Boot reste activé, sa désactivation est exclue.

**Ubuntu sera un angle mort pour le centre de supervision**, n'étant pas couvert par la solution de détection du parc. Je n'ai pas de compensation pleinement satisfaisante à proposer, seulement l'export des journaux vers un collecteur désigné, une rétention portée à six mois, et l'acceptation de toute contrainte supplémentaire.

**La partition ne sera pas chiffrée**, un chiffrement LUKS imposant une saisie à chaque démarrage. Elle ne contient aucune donnée d'entreprise, uniquement du code d'infrastructure, et les secrets du projet y sont chiffrés au repos. Si ce point est jugé rédhibitoire, je chiffre la partition.

## 6. Engagements

1. N'utiliser que les sources officielles décrites, et consigner l'empreinte de chaque composant installé. N'installer aucun logiciel modifié ou de licence contournée.
2. N'ouvrir aucun port depuis Internet vers ce poste, à aucun moment, et n'installer aucun tunnel de contournement.
3. N'accéder au laboratoire que depuis les locaux d'Airbus, sur le port réseau qui m'a été attribué.
4. Refermer la sortie Internet des machines virtuelles une fois leurs paquets installés.
5. Ne jamais écrire de secret en clair dans le dépôt, et conserver actif le contrôle automatique qui le vérifie à chaque commit.
6. Ne stocker aucune donnée d'entreprise sur la partition Ubuntu.
7. Signaler sans délai toute connexion non reconnue dans les journaux, tout comportement anormal, et toute erreur de ma part.
8. Appliquer toute mesure complémentaire demandée par le RSSI, et restituer le poste dans son état d'origine en fin de stage.

**Référentiel utilisé.** ANSSI **DAT-NT-007** v1.3 du 17/08/2015, *Usage sécurisé d'(Open)SSH* ; ANSSI-**BP-028** v2.0 du 03/10/2022, *Configuration d'un système GNU/Linux* ; ANSSI-**PG-083** v3.00 du 20/03/2026, *Mécanismes cryptographiques* ; ANSSI-**PA-048** v1.5 de septembre 2024, *EBIOS Risk Manager*. Documentation éditeur : `sshd_config(5)` d'OpenSSH 9.6p1, documentation libvirt sur le filtrage des réseaux virtuels.

---

*Ce dossier engage son auteur. Toute évolution du périmètre décrit ici fera l'objet d'une nouvelle demande.*